

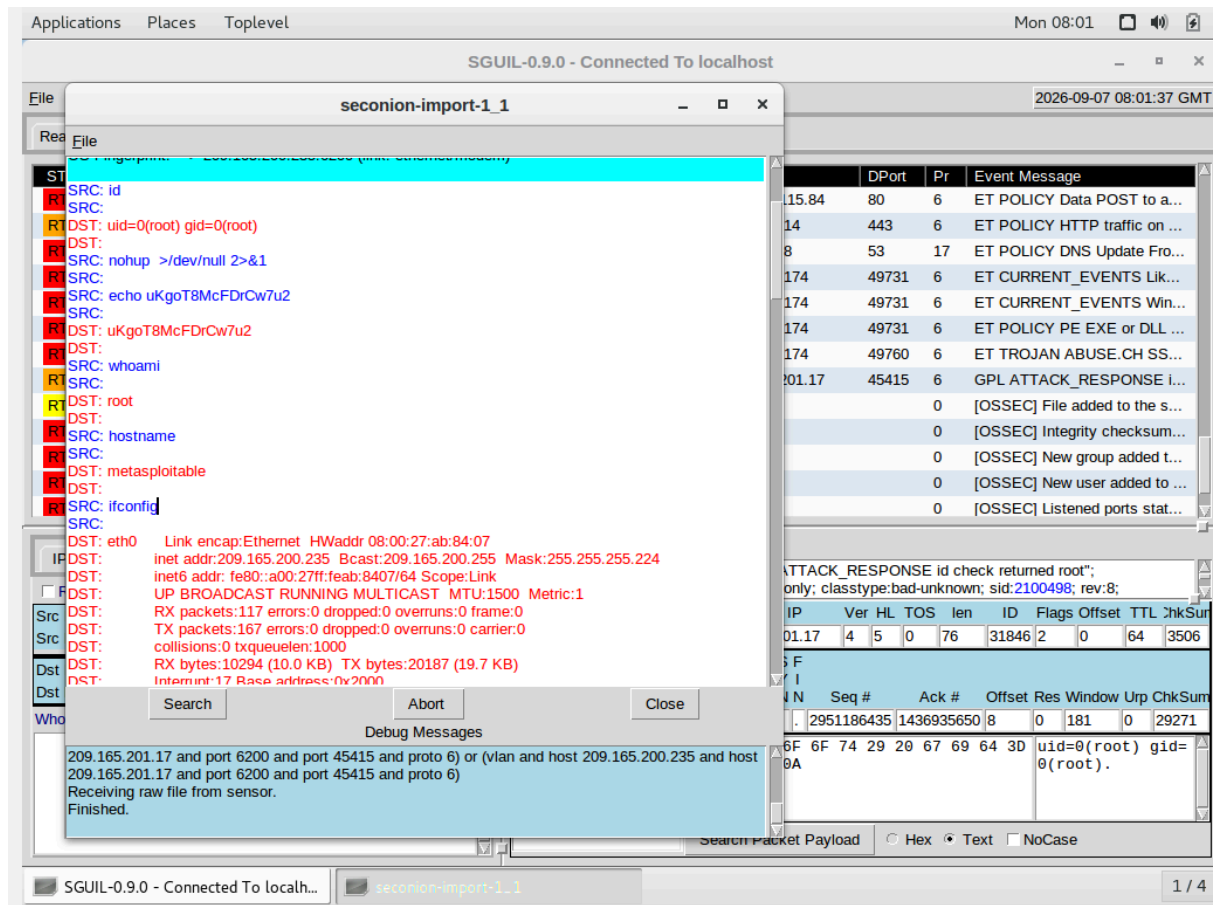
Esercizio Bonus 2: Estrarre un Eseguibile da un PCAP

Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

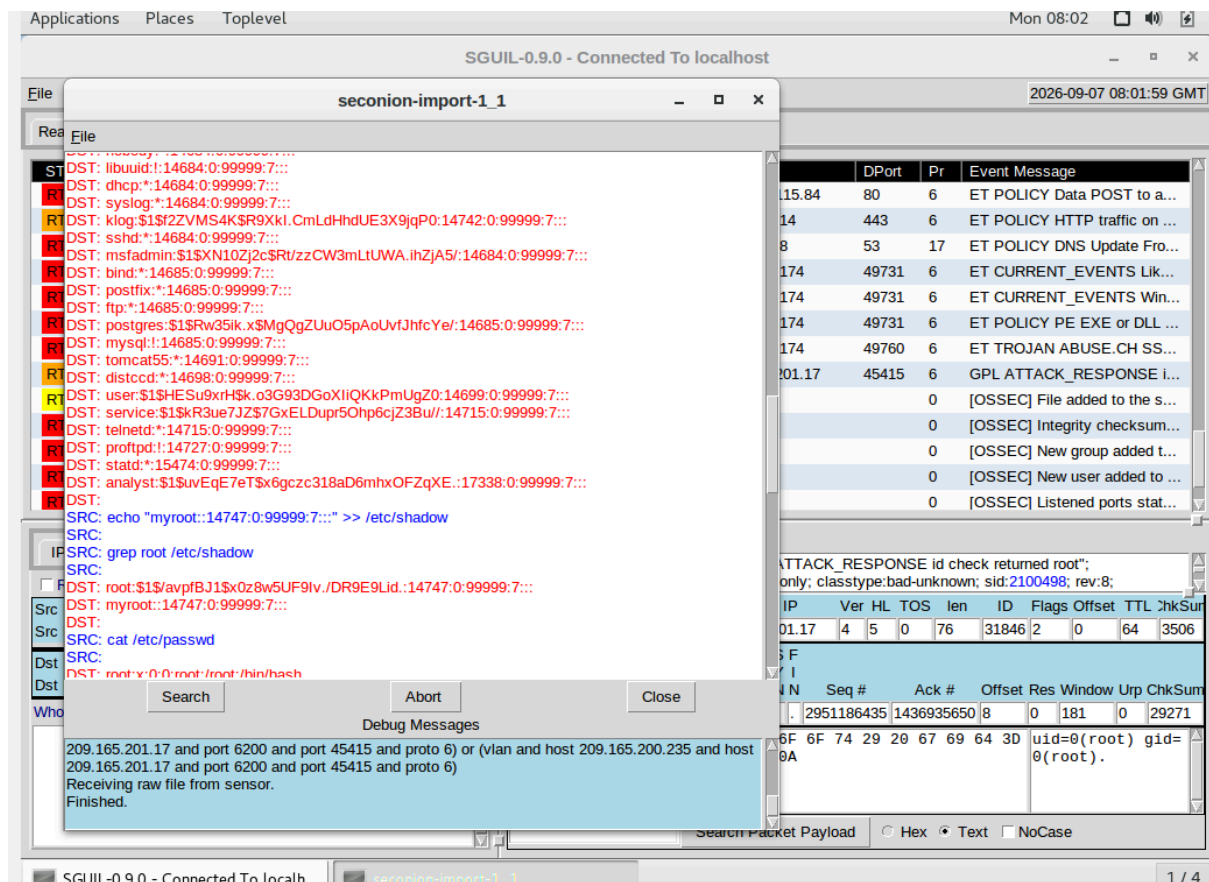
Dalle schermate del transcript di Sguil fornite, l'attaccante ha eseguito diverse interazioni via riga di comando sul sistema compromesso per ottenere e verificare i privilegi di root.

In particolare, sono visibili le seguenti transazioni e comandi:

- **Verifica dell'utente corrente:** Esecuzione del comando `id` per controllare l'UID e i privilegi associati alla sessione.
- **Tentativo di modifica del file delle password:** Tentativi di manipolazione o scrittura nel file `/etc/passwd` e `/etc/shadow`.
- **Aggiunta di un utente privilegiato:** Tentativo di inserire una nuova voce (es. `myroot`) con UID 0 (privilegi di root) direttamente dentro `/etc/passwd`.



- **Visualizzazione del contenuto critico:** Esecuzione del comando `cat /etc/passwd` per leggere la lista degli utenti di sistema configurati.



Cosa hai osservato?

Dalla schermata di Wireshark si osserva l'intera trascrizione della conversazione TCP tra il client e il server compromesso durante l'attacco.

Cosa indicano i colori del testo rosso e blu?

Significato dei colori:

- Il rosso indica il traffico inviato dal client (i comandi impartiti dall'attaccante).
- Il blu indica il traffico inviato dal server (le risposte e gli output restituiti dalla macchina vittima).

L'attaccante esegue il comando whoami sul bersaglio.

Quando l'attaccante esegue il comando **whoami**, il server risponde restituendo **root**, confermando che l'intruso ha ottenuto i privilegi di amministrazione totali sul sistema bersaglio.

Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

Il fatto che l'attaccante esegua comandi come **whoami** e ottenga come risposta **root** (e che utilizzi comandi per manipolare i file di sistema) rivela che ha ottenuto **privilegi**

amministrativi completi (di root) sul computer bersaglio. Questo significa che detiene il controllo totale del sistema compromesso, potendo eseguire qualsiasi operazione critica.

Che tipo di dati ha letto l'attore della minaccia?

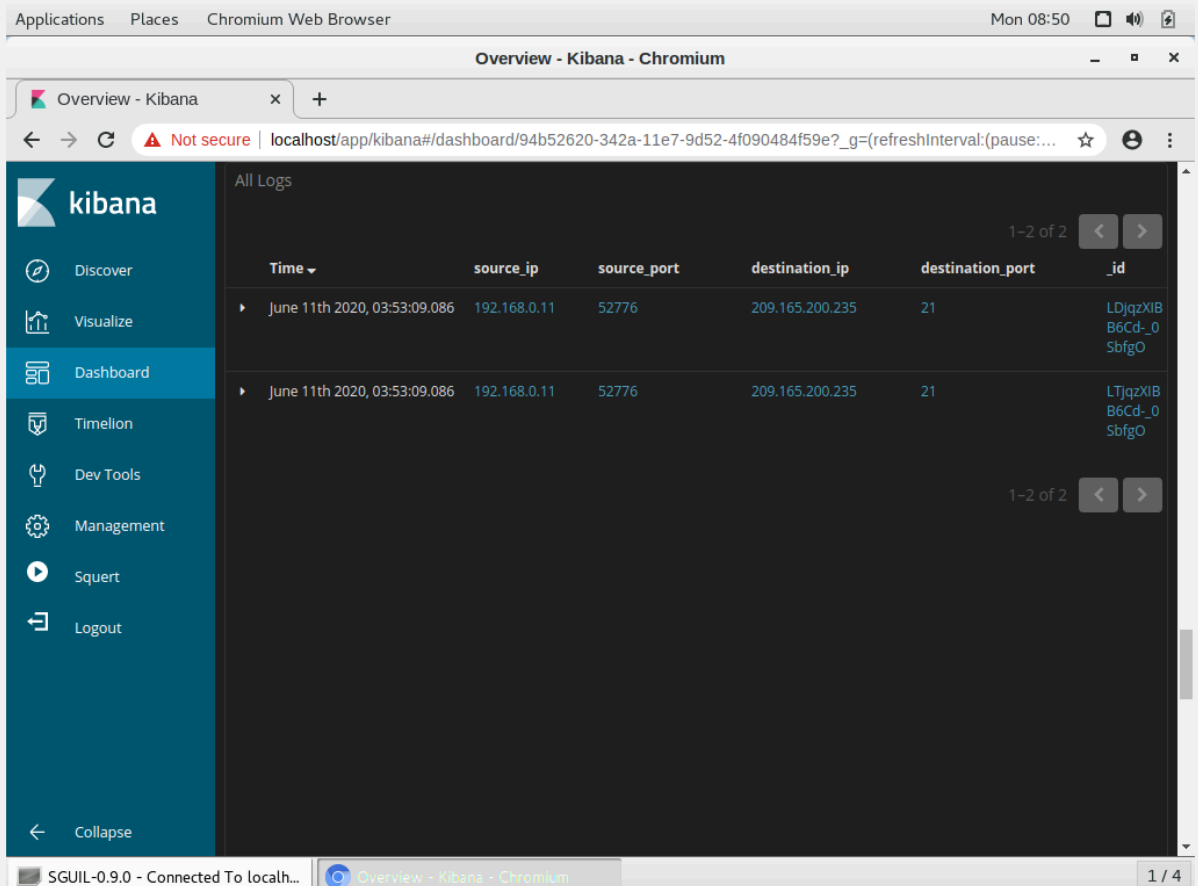
- Ha letto la configurazione delle interfacce di rete del sistema bersaglio tramite il comando `ifconfig`.
- Ha letto il contenuto del file critico degli utenti del sistema (`/etc/passwd`).
- Ha letto il file contenente le password cifrate degli utenti (`/etc/shadow`).
- In sintesi, ha avuto accesso a informazioni sensibili sulla configurazione di rete, sugli account utente e sulle credenziali di sicurezza presenti sulla macchina vittima.

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

Indirizzo IP di origine: `192.168.0.11` (Porta: `52776`)

Indirizzo IP di destinazione: `209.165.200.235` (Porta: `21`)

Timestamp: `11 giugno 2020, 03:53:09.086`



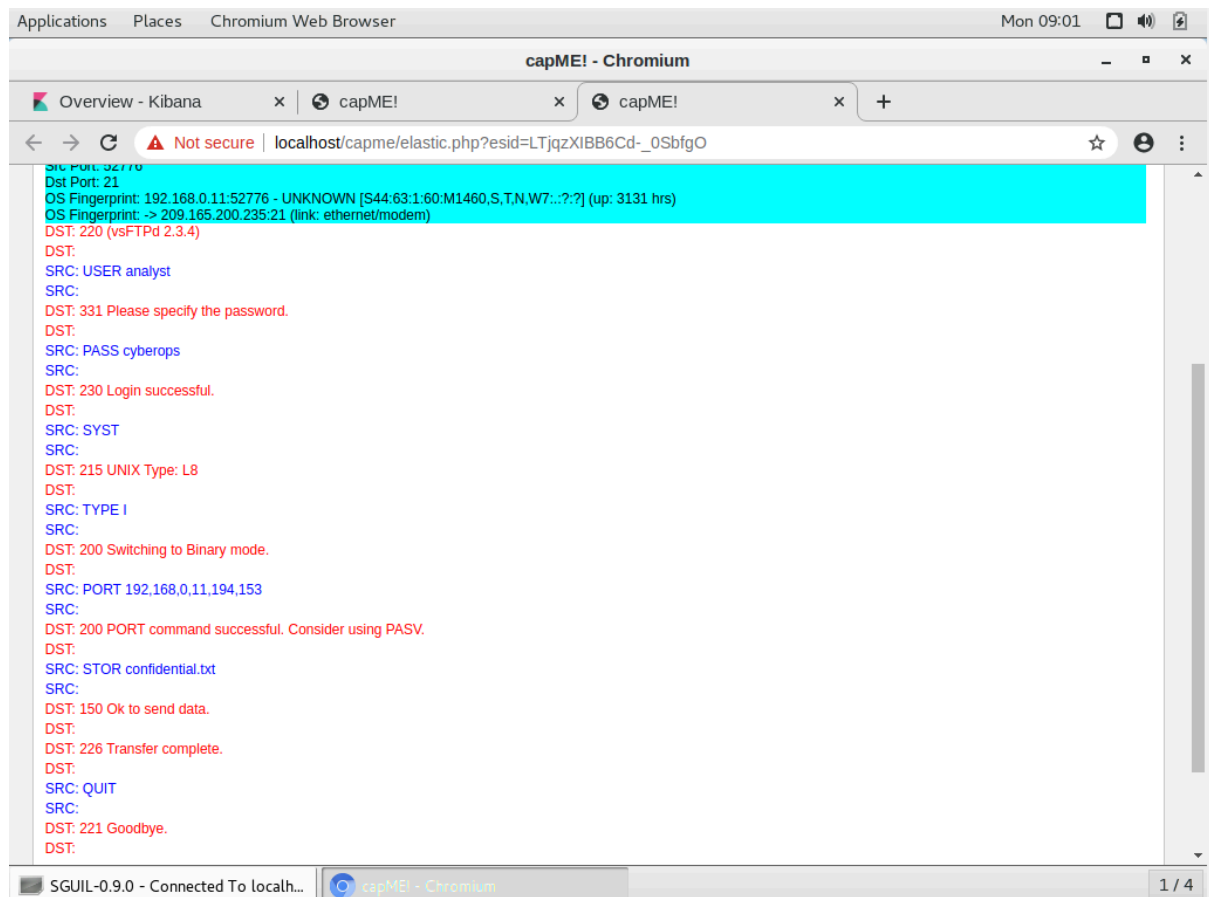
The screenshot shows the Kibana Overview dashboard in a Chromium browser. The left sidebar contains navigation links: Discover, Visualize, Dashboard (selected), Timelion, Dev Tools, Management, Squert, and Logout. The main panel displays 'All Logs' with a table of network traffic. The table has columns for Time, source_ip, source_port, destination_ip, destination_port, and _id. Two log entries are visible, both from 192.168.0.11:52776 to 209.165.200.235:21 at the timestamp 2020-06-11T03:53:09.086Z. The bottom status bar shows 'SGUIL-0.9.0 - Connected To localh...' and 'Overview - Kibana - Chromium'.

Time	source_ip	source_port	destination_ip	destination_port	_id
June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LDJqzXIBB6Cd_0SbfgO
June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LTJqzXIBB6Cd_0SbfgO

Quali sono le credenziali utente per accedere al sito FTP?

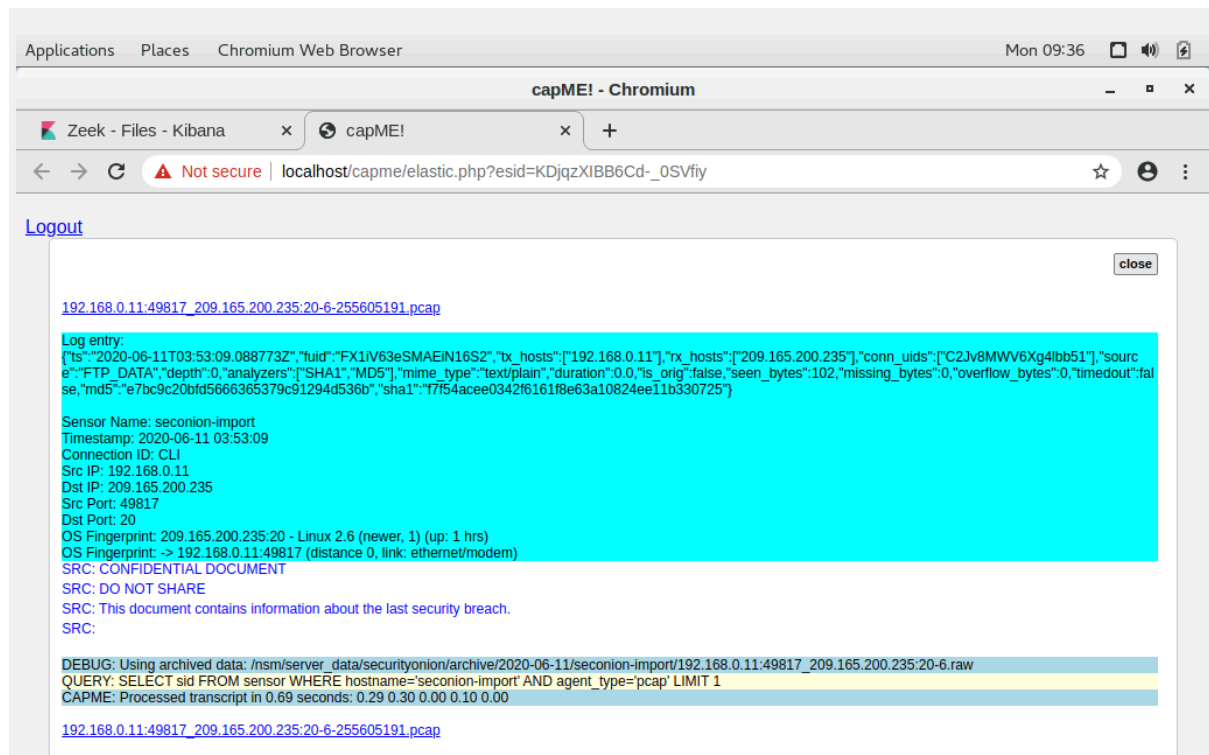
Username: `analyst`

Password: `cyberops`



Qual è il contenuto del file?

- CONFIDENTIAL DOCUMENT
- DO NOT SHARE
- This document contains information about the last security breach.



Quali sono i diversi tipi di file?

Tipi di file (MIME Type): `text/plain`, `image/jpeg`, `image/png`, `text/html`, `image/gif` e `image/x-icon`.

Quali sono le sorgenti dei file elencate?

- **HTTP**: con un conteggio di 22 file.
- **FTP_DATA**: con un conteggio di 1 file.

Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP?

Tipo MIME: `text/plain`

Indirizzo IP di origine (File IP Address): `192.168.0.11`

Indirizzo IP di destinazione (IP Address): `209.165.200.235`

Quando si è verificato questo trasferimento?

l'orario esatto del trasferimento FTP è l'11 giugno 2020 alle 03:53:09.088.

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

Isolare immediatamente la macchina compromessa (**192.168.0.11**) disconnettendola dalla rete locale e da Internet per bloccare ogni ulteriore tentativo di esfiltrazione di dati o movimento laterale verso altri sistemi interni.

Per ripristinare la sicurezza e prevenire nuovi accessi non autorizzati, è necessario procedere con un piano di intervento strutturato:

- **Revoca e rotazione immediata delle credenziali:** Modificare tutte le password degli account di sistema, invalidare le sessioni attive e disabilitare immediatamente l'account FTP compromesso (**analyst / cyberops**). Se l'attaccante ha ottenuto accesso tramite chiavi SSH, revocarle e sostituirle tempestivamente.
- **Bonifica dei file di sistema e degli utenti fittizi:** Rimuovere l'utente non autorizzato creato con privilegi di root (**myroot** con UID 0) all'interno del file **/etc/passwd**. Ripristinare i file **/etc/passwd** e **/etc/shadow** alle versioni originali e pulite utilizzando backup integri precedenti all'attacco.
- **Ispezione e chiusura dei vettori d'accesso:** Analizzare i log di Wireshark e Sguil per identificare la vulnerabilità iniziale o il vettore sfruttato per l'accesso FTP o la shell remota. Chiudere i servizi non necessari e limitare l'accesso remoto esclusivamente tramite VPN sicure e protocolli cifrati.
- **Implementazione di controlli di accesso avanzati:** Introdurre l'autenticazione a più fattori (**MFA**) per tutti gli accessi amministrativi e di rete, configurare regole di firewall rigorose (Network Segmentation) per impedire il traffico non autorizzato verso l'esterno, come il canale FTP utilizzato per prelevare il documento confidenziale.
- **Acquisizione forense:** Eseguire un'acquisizione forense completa della memoria volatile e del disco rigido del sistema vittima prima di qualsiasi formattazione o ripristino, così da preservare le prove digitali utili per comprendere appieno la portata dell'intrusione.